

析毫剖厘——高级攻击案例中技术亮点分析

马茂刚 | 360 天眼实验室

关于360天眼实验室

- 成立于 2014 年 1 月
- 基于360 公司海量多维度安全大数据和数据挖掘技术
- 专注APT等高级威胁的技术研究
- 为客户提供安全检测和防护设备所需要的威胁情报



发展现状



案例分析



影响应对



发展现状

关键字

鱼叉攻击

水坑攻击

高级定向攻击

无文件

高级可持续性威胁

勒索软件

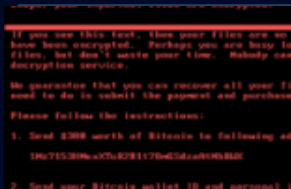
远程访问木马

持久化

工业控制系统

威胁指标

典型事件



WanaCry

Petya



Pinkslipbot

dridex



Industroyer

威胁情报

战略情报

战役情报

战术情报

TTPs

攻击工具

网络或主机特征

域名

IP地址

HASH

艰难

挑战

恼人

简单

容易

微不足道



案例分析



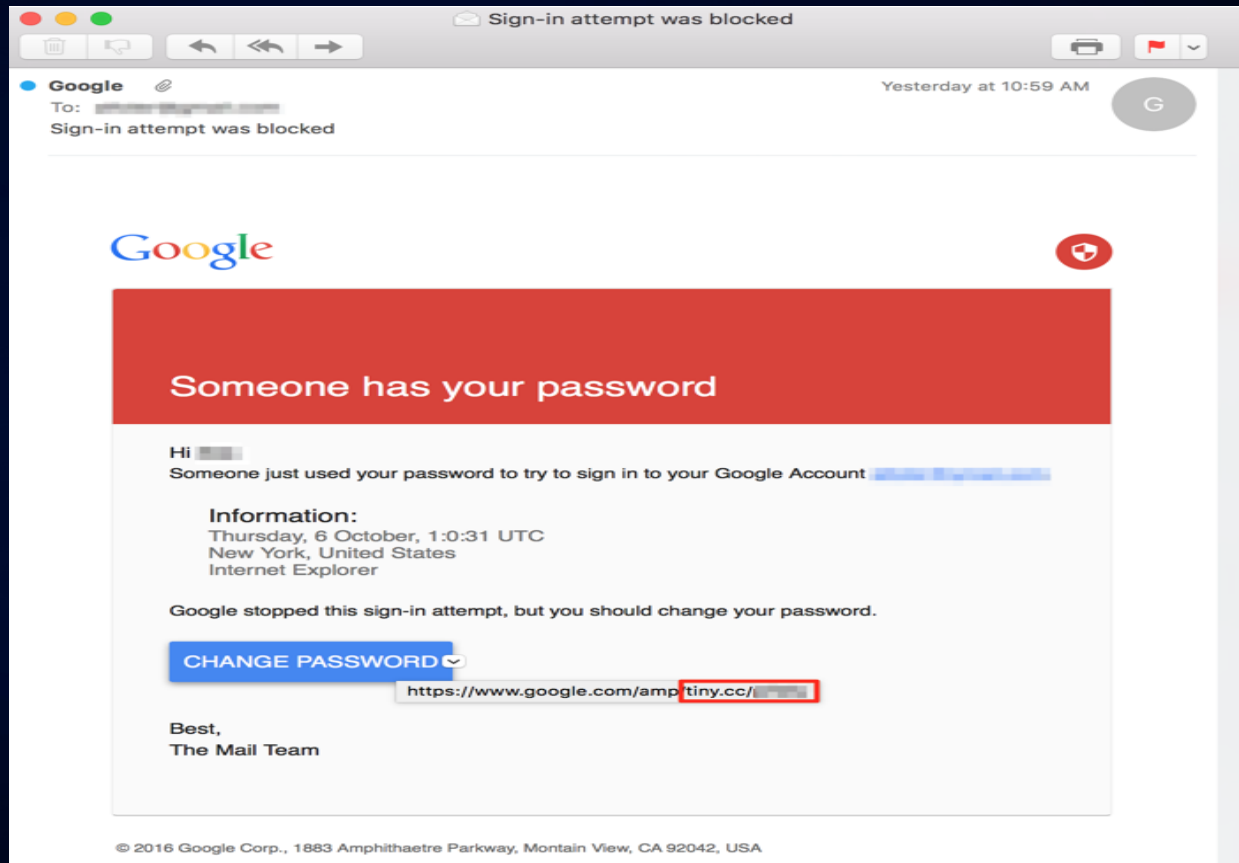
变造后的泄露

鱼饵制作





变造后的泄露





变造后的泄露

```
http://myaccount.google.com-changepassword-securitypagesettingmyaccountgooglepagelogin.id833.ga/  
security/signinoptions/password?e=<email_addr>&fn=<full_Name>&n=<first_name>&img=<link to  
google+profile avatar>&id4242=<redacted>&continue=https://myaccount.google.com
```



鱼饵的制作过程





Punycode

← → ↻ 🏠 ⓘ baidu.com



ERROR

The requested URL could not be retrieved

当尝试取回该 URL 时遇到下面的错误：<http://xn--baidu-2ua.com/>

不能由主机名 "xn--baidu-2ua.com" 确定 IP 地址。

DNS 服务器返回了：

Name Error: The domain name does not exist.



持久化



持久化

官方

- 启动目录
- Run注册表

技巧

- 关联程序劫持
- COM劫持
- 白利用

高级

- ?

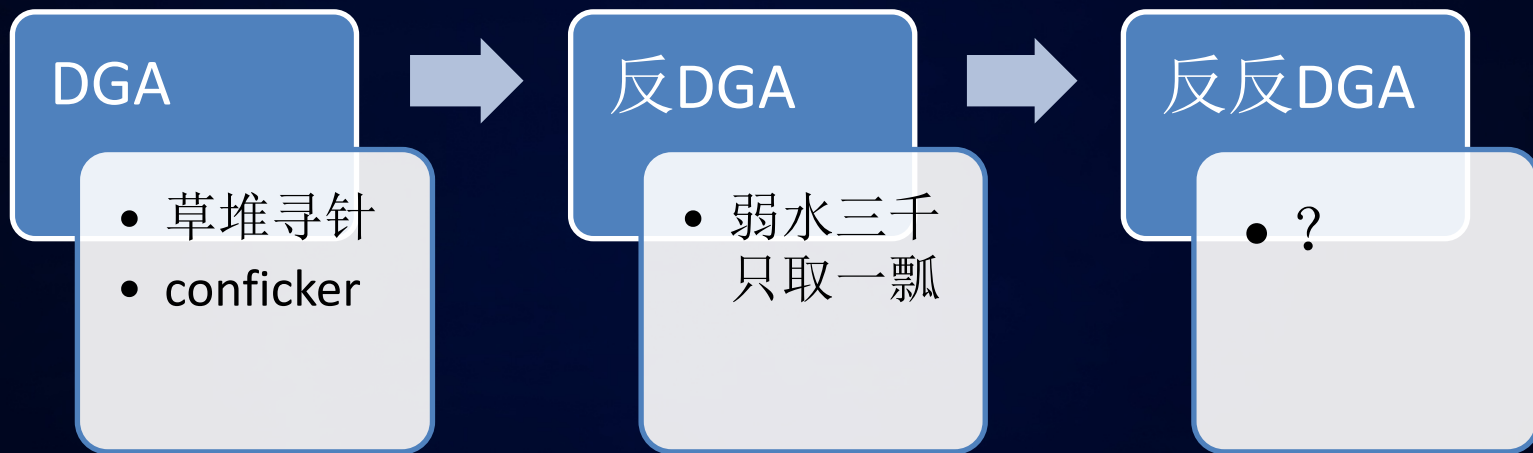
持久化





反反DGA

PinkslipBot网银木马



Gameover

1024ct71ksdgaae512rsnkep4c.net

2017-07-25

反反DGA之一

NS黑名单

```
root@kali:~# whois ajihynoxo.pl
```

```
DOMAIN NAME:          ajihynoxo.pl
registrant type:      organization
nameservers:          sinkhole.cert.pl.
                      sinkhole112.cert.pl. [148.81.111.112]
created:              2013.07.23 02:43:36
last modified:        2013.08.02 11:23:23
renewal date:         not defined

no option
```

反反DGA之二

虚假DGA

DGA还是原来的DGA
功能却已经成了sinkhole



新鲜玩法：IPGA

首现于勒索软件sega中

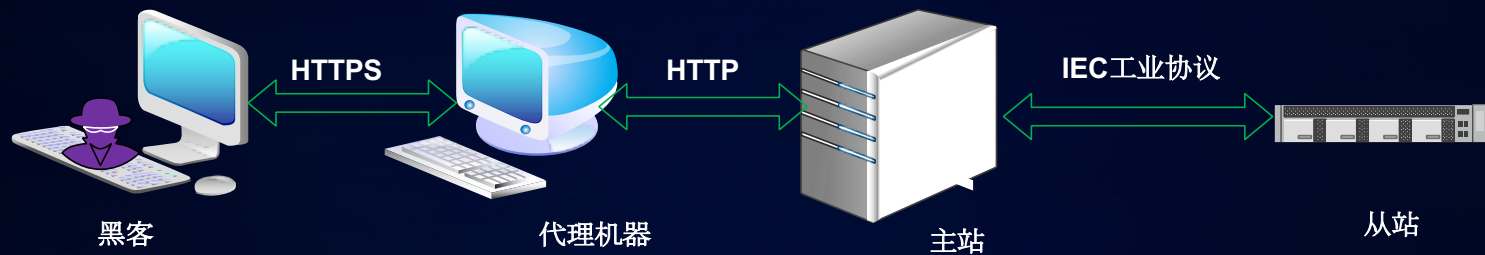
缺点？



线上线下载复合式作业
工控协议



攻击过程



通信模块



loader模块



payload模块



清理模块

工控协议

向从站发送执行合闸数据包

0x68 0x0E 0x02 0x00 0x02 0x00 0x2D 0x01 0x06 0x00 0x01 0x00 0x0A 0x00 0x00 0x01



Poweliks家族

无文件启动

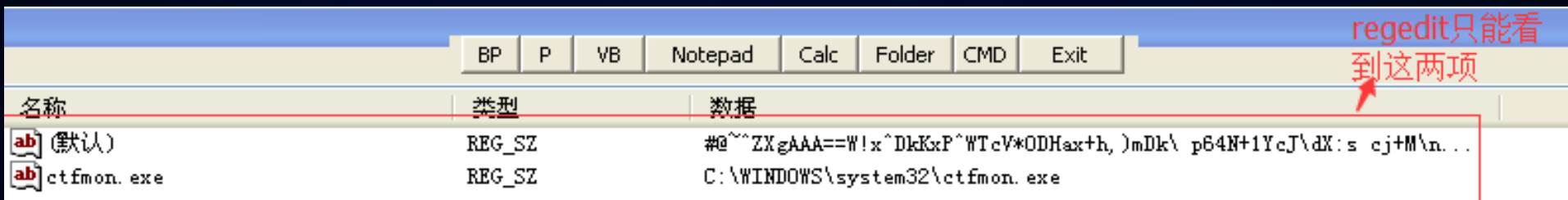
注册表隐藏

**Poweliks -
A Fileless Malware**

无文件启动

```
rundll32.exe javascript:"..\mshtml,RunHTMLApplication ";alert('foo');
```

注册表隐藏效果



注册表原理

0120h:	5C 00 63 00	74 00 66 00	6D 00 6F 00	6E 00 2E 00	\.c.t.f.m.o.n...
0130h:	65 00 78 00	65 00 22 00	0D 00 0A 00	22 00 00 00	e.x.e."....."...
0140h:	61 00 22 00	3D 00 22 00	72 00 75 00	6E 00 64 00	a.".=."r.u.n.d.
0150h:	6C 00 6C 00	33 00 32 00	2E 00 65 00	78 00 65 00	l.l.3.2...e.x.e.
0160h:	20 00 6A 00	61 00 76 00	61 00 73 00	63 00 72 00	.j.a.v.a.s.c.r.
0170h:	69 00 70 00	74 00 3A 00	22 00 5C 00	5C 00 2E 00	i.p.t.:.".\.\...
0180h:	2E 00 5C 00	5C 00 6D 00	73 00 68 00	74 00 6D 00	..\.\.m.s.h.t.m.
0190h:	6C 00 2C 00	52 00 75 00	6E 00 48 00	54 00 4D 00	l.,.R.u.n.H.T.M.
01A0h:	4C 00 41 00	70 00 70 00	6C 00 69 00	63 00 61 00	L.A.p.p.l.i.c.a.
01B0h:	74 00 69 00	6F 00 6E 00	20 00 22 00	3B 00 64 00	t.i.o.n. ".;d.
01C0h:	6F 00 63 00	75 00 6D 00	65 00 6E 00	74 00 2E 00	o.c.u.m.e.n.t...

Petya勒索蠕虫

MBR DBR MFT





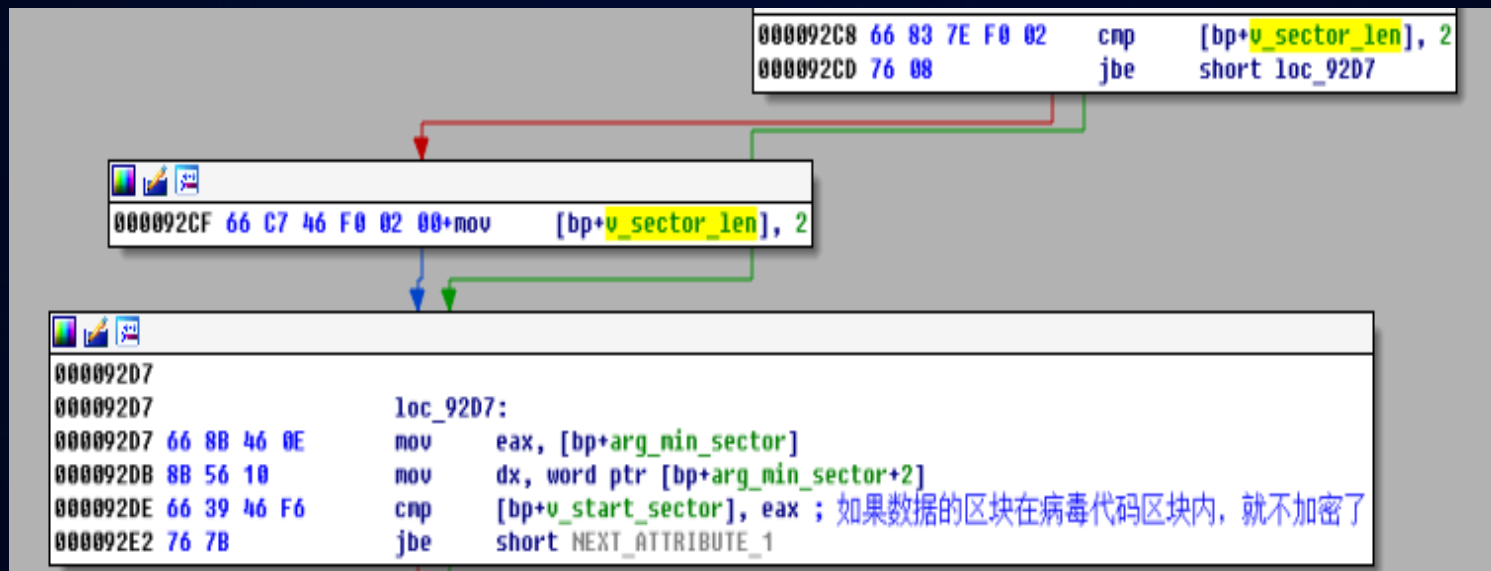
Petya勒索蠕虫

```

0000928E 66 FF 76 D0      push    large [bp+var_cluser_num]
00009292 8A 46 16         mov     al, [bp+arg_SectorsPerCluster]
00009295 2A E4           sub     ah, ah
00009297 2B D2           sub     dx, dx
00009299 52             push    dx
0000929A 50             push    ax
0000929B 89 86 C4 F5      mov     word ptr [bp+var_A3C], ax
0000929F 89 96 C6 F5      mov     word ptr [bp+var_A3A], dx
000092A3 66 58           pop     eax                ; eax:SectorsPerCluster
000092A5 66 59           pop     ecx                ; ecx:var_cluser_num
000092A7 66 F7 E1        mul     ecx
000092AA 66 89 46 F0      mov     [bp+v_sector_len], eax ; 保存:簇的数量*扇区数/每簇
000092AE 66 8B 86 C4 F5      mov     eax, dword ptr [bp+var_A3C]
000092B3 66 F7 66 D4      mul     [bp+var_sector_num]
000092B7 66 03 46 0E      add     eax, [bp+arg_min_sector]
000092BB 66 89 46 F6      mov     [bp+v_start_sector], eax ; 保存: 起始簇号*扇区数/簇, 得到起始扇区
000092BF 66 83 7E F0 00    cmp     [bp+v_sector_len], 0 ; 如果数据长度的扇区数目为0的话, 就寻找下一个
000092C4 0F 84 97 00      jz      NEXT_ATTRIBUTE_1
    
```



Petya勒索蠕虫





趋势与应对

趋势

文件特征：无PE实体，数字签名

流量特征：ssl基于正规签名的方式加密通讯

目标特征：具有针对性不同行业，更底层

协同

“威胁情报对于防御方来说是规则和线索，
对攻击方来说则是攻击资源和痕迹”

外部威胁情报平台（C&C，IOC等）

威胁情报标准化（IOC，STIX等标准）

http://www.antiy.com/response/2016_Antiy_Annual_Security_Report/2016_Antiy_Annual_Security_Report.pdf

联动

设备：IDS系统、交换机、防火墙、网管设备等

人才：人工智能专家、安全漏洞专家、安全防护专家

我们能做些什么？

参考

- http://www.antiy.com/response/2016_Antiy_Annual_Security_Report/2016_Antiy_Annual_Security_Report.pdf
- <https://www.govcert.admin.ch/blog/27/sage-2.0-comes-with-ip-generation-algorithm-ipga>
- <https://www.symantec.com/connect/blogs/poweliks-click-fraud-malware-goes-fileless-attempt-prevent-removal>
- https://www.welivesecurity.com/wp-content/uploads/2017/06/Win32_Industroyer.pdf
- https://www.symantec.com/content/en/us/enterprise/media/security_response/whitepapers/w32_qakbot_in_detail.pdf
- <https://hshrzd.wordpress.com/2017/05/25/hijacking-extensions-handlers-as-a-malware-persistence-method/>





Thank you

马茂刚 | 360 天眼实验室